

SURVEILLANCE GOVERNANCE SERIES | BRIEF 03 | POLICY BRIEF | UPDATED SEPTEMBER 30, 2026

BUY OUTCOMES, NOT TECHNOLOGY

A risk-based procurement framework for connected, data-intensive, and AI-enabled public-safety systems.

NCI RECOMMENDATION / DECISION STANDARD

Public-safety procurement should begin with a lawful public purpose and a measurable need, then apply scrutiny proportional to risk. The contract should preserve government control over data, security, evaluation, material changes, continuity, and exit. A scorecard can organize judgment, but legal authority, basic security, auditability, and data control are hard gates.

Donavan Norman | Founder & Executive Director, Northstar Civic Institute

Published September 2026 | Updated September 30, 2026

Evidence update at a glance

June 30

NIST finalized SP 800-18 Rev. 2, integrating security, privacy, and cybersecurity supply-chain plans for systems. ^[3]

5 pilots

Michigan awarded \$2 million in August 2026 for advanced-air-mobility pilots pairing five companies with five state departments. ^[12]

July 8

NIST finalized SP 1326, a supplier due-diligence guide organized around ownership/control, provenance, resilience, cyber practices, and supply-chain tiers. ^[4]

26 firms

Michigan announced another \$2 million on September 17 for mobility and manufacturing projects; the program reported more than \$5 million awarded to 69 companies over three rounds. ^[14]

What the 2026 update adds

The procurement environment has moved beyond general calls for responsible technology. NIST finalized two directly usable system and supplier resources in summer 2026. SP 800-18 Rev. 2 treats security, privacy, and cybersecurity supply-chain plans as connected system plans and emphasizes purpose, data flows, components, roles, controls, and lifecycle decisions. SP 1326 provides a quick-start structure for supplier due diligence. ^[3-4]

NIST also released an initial public draft of the TEVV-Athlon framework in August 2026. It is designed to structure test, evaluation, verification, and validation of real-world AI systems and is open for comment through October 6. The existing AI Risk Management Framework remains available, but NIST states that AI RMF 1.0 is being revised. ^[6-7]

STRATEGIC IMPLICATION

Public agencies now have stronger building blocks for turning procurement review into an evidence record: define the system boundary, map the data and decision flow, examine the supplier, test the actual use case, control changes after award, and require results at renewal.

Michigan is scaling capability while statewide rules remain incomplete

Michigan's ALPR proposals remain pending rather than enacted statewide law. HB 5492 and HB 5493 were introduced on January 29, 2026, and referred to the House Judiciary Committee. SB 1131 was introduced on July 29 and referred to the Senate Civil Rights, Judiciary, and Public Safety Committee. The bills take different approaches to governmental and private systems, retention, access, reporting, remedies, and permitted use. ^[9-11]

Contemporaneous reporting in April 2026 identified ALPR use across more than 125 Michigan cities and counties. Because statewide legislation remains pending, local policy and contract terms continue to do much of the practical governance work. ^[15]

The same implementation question is emerging in advanced air mobility. In August 2026, Michigan awarded \$2 million for five pilots pairing companies with EGLE, DNR, MDOT, MSP, and MDARD for environmental monitoring, mapping and wildfire support, roadway intelligence, drone detection, and pesticide-drift investigation. The state's 2025 AAM report described more

than \$42 million in public and private investment and nine active test sites. On September 17, 2026, the state announced another \$2 million for 26 mobility, defense, aerospace, and manufacturing companies and reported more than \$5 million awarded to 69 firms across three rounds. ^[12-14]

These investments are not proof that any specific system should be purchased. They increase the need for repeatable supplier, system, contract, and outcome controls as pilots become operational programs.

Federal ALPR policy now adds another governance layer

H.R. 10366, the No Federal License-Plate Observation and Camera Keeping Act, was introduced in the U.S. House on September 14, 2026 and referred to the Committee on Transportation and Infrastructure. The proposal would condition apportioned surface-transportation funding on states adopting specified restrictions for automated license-plate-reader use. It remains pending legislation and does not create a current federal mandate for Michigan agencies. ^[16]

Implementation consideration: Agencies evaluating procurement resilience can examine whether retention, permitted-use, sharing, or deletion rules can be changed without replacing the entire system if federal or state requirements later tighten.

Start with four hard gates

Gate	Question that must be answered before scoring	Pause condition
Lawful authority and public purpose	What legal authority and defined public-safety purpose support the intended use?	Purpose is vague, authority is missing, or the use would violate law or constitutional protections.
Minimum control	Can the government control access, logging, retention, sharing, security, audit, and deletion?	Sensitive data or consequential functions lack basic controls or cannot be independently audited.
Evidence access	Can the agency obtain enough information to test performance, investigate errors, and disclose material limitations?	Vendor terms or system design prevent meaningful evaluation, error investigation, or oversight.
Exit and continuity	Can the agency export data, transition operations, delete information, and withstand supplier or product disruption?	No credible exit, deletion, transition, or continuity path exists.

A high numerical score cannot cure a failed gate. This is especially important for biometric, persistent-surveillance, integrated-data, and consequential AI systems, where one missing control can dominate the risk.

An eight-step procurement lifecycle

1. Define the problem and baseline. State the public-safety outcome, current performance, affected population or geography, and credible non-technology alternatives.
2. Set the risk tier. Consider data sensitivity, persistence, automation, rights impact, integration, scale, and dependence on a supplier.
3. Build the system plan. Document purpose, system boundary, components, data flows, roles, controls, and lifecycle using SP 800-18 Rev. 2 as a practical model.
4. Review evidence and supplier. Separate vendor claims from independent evidence and conduct proportionate supplier due diligence using SP 1326.
5. Test the real use case. Establish test data, operating conditions, success criteria, error analysis, human review, and comparison points; use TEVV concepts for AI-enabled functions.
6. Contract for performance and control. Resolve data rights, cybersecurity, audit, change notice, evaluation, continuity, portability, termination, and deletion before deployment.
7. Monitor deployment drift. Track model, software, data-source, integration, workflow, staffing, and use-policy changes after award.
8. Make renewal affirmative. Report outcomes, total cost, incidents, changes, risks, and alternatives on a fixed schedule, then continue, modify, narrow, expand, or exit.

NIJ's 2025 adoption guide reinforces the same basic order: problem analysis first, followed by technical, operational, and governance review. ^[4]

Match review intensity to risk

Tier	Typical characteristics	Review expectation
Tier 1 - routine	Low sensitivity, limited personal data, minimal integration, and little effect on rights or operational decisions.	Streamlined need, security, supplier, cost, and records review.
Tier 2 - significant	Sensitive data, meaningful integration or workflow change, material vendor dependence, or moderate rights and privacy impact.	Full impact assessment, legal/privacy/data review, system plan, measurable implementation plan, and formal renewal.
Tier 3 - high impact	Biometrics, persistent surveillance, consequential AI or automation, broad data fusion, or systems likely to materially affect liberty, rights, or enforcement.	Enhanced validation, senior approval, independent or cross-functional review, time-limited pilot where feasible, public use policy, and stronger audit/change/exit controls.

Risk tiering should affect process, not predetermine the decision. A Tier 3 system may be appropriate when authority, need, evidence, controls, and outcomes support it. A Tier 1 tool can still fail if the vendor, contract, or security posture is weak.

Use a scorecard as a record, not a prediction

Category	Points	What must be demonstrated
Problem and measurable outcomes	15	Specific need, baseline, alternatives, affected population, and success measures.
Evidence and independent validation	15	Quality, relevance, limits, local transferability, and test design.
Operational capacity	10	Staffing, training, dispatch, analysis, maintenance, and downstream workload.
Privacy and civil rights	15	Authorized and prohibited uses, necessity, proportionality, human review, and redress where relevant.
Data governance	10	Collection, access, retention, sharing, secondary use, logging, deletion, and government control.
Cybersecurity and supplier risk	10	Security baseline, incident response, provenance, ownership/control, subcontractors, resilience, and monitoring.
Interoperability and continuity	5	Integration without unnecessary lock-in; export, migration, and continuity path.
Total cost and opportunity cost	10	Full lifecycle cost, workload, grant cliff, price-change exposure, and alternatives.
Transparency and evaluation	5	Use policy, performance reporting, audit, complaint handling, and independent evaluation.
Exit and renewal	5	Termination, transition, export, deletion, and affirmative renewal criteria.

HOW TO READ THE SCORE

Scores expose gaps and document the record. They do not manufacture certainty. A failed hard gate blocks procurement regardless of total points. Significant weakness should lead to cure, narrower scope, a pilot, a different supplier, or no award.

Supplier review belongs inside the purchase decision

NIST SP 1326 organizes supplier due diligence around five components: foreign ownership, control, or influence; provenance; resilience; foundational cybersecurity practices; and supply-chain tiers. The guide is scoped to information and communications technology suppliers, which fits many connected sensors, cloud platforms, analytics products, and AI-enabled systems used in public safety. ^[4]

Supplier question	Evidence to request
Who ultimately owns or controls the supplier and material subcontractors?	Corporate structure, controlling interests, locations, sanctions or legal restrictions, and notification of change of control.
Where did critical hardware, software, models, and data components originate?	Bill of materials or equivalent provenance information appropriate to risk; development and hosting locations; critical dependencies.
Can the service withstand disruption?	Business continuity, disaster recovery, redundancy, financial stability, product-lifecycle plans, and subcontractor substitution.
Are foundational cyber practices credible?	Security program, vulnerability management, independent assessments, incident history, patching, logging, and notification commitments.
How deep is the supply chain?	Material vendors, cloud and model providers, data sources, integrators, support firms, and flow-down contract obligations.

Create a living system plan, not a one-time form

NIST SP 800-18 Rev. 2 links security, privacy, and supply-chain planning. It calls for documentation of the system purpose, components, environments, data flows, controls, roles, and information lifecycle. It also emphasizes machine-readable formats and continuous risk information rather than static point-in-time paperwork. ^[3]

- System boundary and intended tasks, including integrations and external services.
- Data created, collected, inferred, received, shared, stored, exported, and deleted.
- Named owners for operations, security, privacy, legal compliance, records, evaluation, and contract management.
- Controls in place, planned controls, known gaps, exceptions, and target dates.
- Supplier and subcontractor dependencies, hosting, model providers, and critical support services.
- Version, change, incident, complaint, and audit history throughout the contract.

The federal Privacy Impact Assessment model is also useful procedurally even when it is not legally required of a local agency. It asks how identifiable information is collected, stored, protected, shared, and managed across the lifecycle. ^[8]

Control model and capability changes after award

AI features can appear in ALPR search, video analytics, weapons detection, identity matching, report generation, investigative search, prioritization, and decision support. The version demonstrated during procurement may not be the version operating months later. Contracts and system plans should distinguish routine maintenance from a material capability change.

Change	Required response
Model, algorithm, threshold, or training-data change	Advance notice; updated validation; error and subgroup analysis appropriate to the use; approval before production when material.
New feature or task	New purpose and authority review; updated risk tier, system plan, user training, and public-use policy.
New data source or integration	Updated data map, privacy/security review, retention/sharing terms, provenance, and access controls.
Vendor or subcontractor change	Supplier due diligence, contract flow-down, continuity analysis, and data-location review.
Observed deployment drift	Corrective action, retraining or rollback, scope limitation, user guidance, and documented reauthorization.

NIST's TEVV-Athlon draft offers a structured way to think about real-world AI testing and evaluation. It is a draft, not a binding standard, but procurement teams can already use its core lesson: test the system in the actual task, context, and operating environment rather than relying only on a general benchmark. ^[7]

NIST Privacy Framework 1.1 should also be cited accurately. As of this update, the final 1.1 version is still listed as forthcoming; the initial public draft remains the available update. ^[5]

Treat procurement, exit and change as lifecycle controls

Procurement and exit should not become separate governance silos. For consequential systems, the same case record should follow the system from need definition through purchase, deployment, material changes, complaints or incidents, evaluation, renewal and termination.

- Keep the nine core questions constant: Purpose, Authority, Procurement, Data, Decision, Human Control, Evaluation, Accountability and Exit.
- Add standard lifecycle fields: solicitation and vendor details, contract controls, renewal dates, termination rights, data export and deletion requirements, and a dated change timeline.
- Maintain a verified incident and complaint history for research and oversight, but do not treat a running public blacklist of agencies or vendors as the default governance product.

This structure keeps the framework usable across surveillance and sensor systems, automated administrative decisions, and digital infrastructure without turning every control question into a separate program.

Michigan case: MiDAS shows why the lifecycle matters

Michigan's unemployment system provides an unusually complete automated-decision case file. MiDAS was fully implemented in 2013. The Michigan Office of the Auditor General later documented security, access and claim-processing control weaknesses. Litigation challenged automated fraud determinations, and the Michigan Attorney General announced a \$20 million settlement resolving a civil-rights class action alleging false fraud accusations and wrongful seizures. UIA is now transitioning to the MiUI replacement platform, with benefits functionality scheduled to launch November 9, 2026. [17-19]

The value of MiDAS is not that it represents every AI system. It is that the public record lets researchers follow one consequential system across authorization, automation, human review, notice, appeal, audit, remediation, replacement and exit.

Michigan's current AI guidance also supports a lifecycle approach. DTMB expressly describes its public AI document as guidance rather than policy or a procurement process; external tools that store, analyze or process state proprietary data must receive an Authority to Operate through MiSAP, and software purchases remain subject to state procurement rules. MDE's current district resources emphasize purposeful use, privacy, human oversight, equity, transparency and continuous improvement. [20-21]

Minimum contract controls

Contract area	Question that must be answered before signature
Performance	What service levels and outcome reports distinguish uptime from public-safety value?
Data	Who controls data; where are they stored; who may access, share, combine, retain, export, and delete them?
Secondary use and model training	May agency data be used for analytics, product development, or training? Under what approval and de-identification rules?
Security and incidents	What baseline, vulnerability, logging, notification, remediation, insurance, and subcontractor duties apply?
Audit and evaluation	What records can the government, oversight bodies, and qualified evaluators access, and can findings be published without vendor veto?
Material changes	Which algorithm, model, feature, integration, data-practice, hosting, ownership, or price changes require notice and approval?
Records and legal process	How will the vendor support FOIA, discovery, litigation holds, evidence preservation, chain of custody, and legally required disclosure?
Continuity and grant cliff	What happens if the product is discontinued, a subcontractor fails, funding ends, price changes materially, or service is unavailable?
Exit	How will termination, transition, export, deletion, hardware removal, and post-contract security be verified?

Make decision rights explicit

Role	Primary responsibility
Program owner	Defines need, operating model, outcomes, staffing, and baseline.
Procurement and finance	Runs competition, validates total cost, negotiates commercial terms, and monitors price and grant exposure.

Role	Primary responsibility
IT and cybersecurity	Reviews architecture, integrations, identity, logging, vulnerabilities, incidents, hosting, and continuity.
Legal, privacy, civil rights, and records	Reviews authority, use limits, data lifecycle, disclosure, evidence, complaints, and redress.
Independent or cross-functional reviewer	Challenges evidence, risk tier, validation, proportionality, and evaluation design for higher-impact systems.
Approving official	Accepts residual risk and authorizes pilot, award, material change, and renewal.
Evaluator and contract manager	Tracks outcomes, incidents, costs, changes, obligations, and exit readiness after deployment.

Cross-functional review should not diffuse accountability. Each required decision needs a named owner, a written recommendation, and an identified approving official.

A 90-day implementation path for Michigan agencies

9. Adopt a two-page Public Safety Technology Impact Assessment before an RFP, pilot, grant commitment, or sole-source purchase.
10. Classify systems into routine, significant, and high-impact tiers and publish the triggers for each tier.
11. Create a system-plan template aligned to SP 800-18 Rev. 2 and a supplier checklist aligned to SP 1326.
12. Publish model clauses for data control, security, audit, model change, records, continuity, portability, deletion, and exit.
13. Require a time-limited pilot and defined comparison when evidence is weak or the use is high-impact and a pilot is feasible.
14. Maintain a public inventory of covered systems, purposes, vendors, contract dates, policies, and evaluation schedules, with lawful security redactions.
15. Make renewal an affirmative written decision explaining outcomes, total cost, incidents, changes, residual risk, alternatives, and exit readiness.

The pending ALPR bills provide a useful test case. Agencies can map the proposed statutory safeguards against their own policies and contracts now, identify which controls require statewide law, and implement the remaining controls through procurement before legislation is resolved.

Bottom line

The key procurement question is not whether a product is innovative. It is whether the public agency has lawful authority, a defined need, credible evidence, operational capacity, data and security control, a resilient supplier, an evaluable contract, and an exit path. Procurement, change management and exit should be recorded as one lifecycle rather than separate governance exercises. The 2026 NIST updates make that record easier to build, and Michigan's MiDAS history shows why the record has to survive beyond initial purchase.

Selected authorities and current sources

Legislative status and current-source references were checked through September 30, 2026. Pending bills, public-comment proceedings, draft standards and agency programs may change after publication.

- [1] [NIJ Criminal Justice Technology Adoption and Implementation Guide](#). April 2025.
- [2] [NIST Cybersecurity Framework 2.0](#). Final, February 2024.
- [3] [NIST SP 800-18 Rev. 2 - security, privacy and C-SCRM system plans](#). Finalized June 30, 2026.
- [4] [NIST SP 1326 - C-SCRM Due Diligence Assessment Quick-Start Guide](#). Finalized July 8, 2026.
- [5] NIST Privacy Framework 1.1 project page. Version 1.1 remained listed as coming soon as of September 30, 2026; the initial public draft remains available.
- [6] [NIST AI Risk Management Framework](#). AI RMF 1.0 is being revised; current framework and resources remain available.
- [7] [NIST TEVV-Athlon Framework for Evaluating AI Systems](#). NIST AI 200-2 initial public draft; comments due October 6, 2026.
- [8] [U.S. Department of Justice - Privacy Impact Assessments](#). Federal procedural model for documenting personal-data use.
- [9] [Michigan House Bill 5492 - private ALPR systems](#). Introduced January 29, 2026; pending House Judiciary.
- [10] [Michigan House Bill 5493 - governmental ALPR systems](#). Introduced January 29, 2026; pending House Judiciary.
- [11] [Michigan Senate Bill 1131 - governmental ALPR systems](#). Introduced July 29, 2026; pending Senate Civil Rights, Judiciary, and Public Safety.
- [12] [Michigan LEO: \\$2 million awarded for five AAM public-service pilots](#). August 12, 2026; five companies paired with five state departments.

- [13] [Michigan 2025 Advanced Air Mobility annual report announcement](#). State reported more than \$42 million in public and private investment and nine active test sites.
- [14] [Michigan LEO: September 2026 Make It in Michigan mobility awards](#). September 17, 2026; \$2 million to 26 companies; more than \$5 million to 69 companies across three rounds.
- [15] [Michigan Public: ALPR adoption and policy debate](#). April 8, 2026; reported use across more than 125 Michigan cities and counties.
- [16] GovInfo: H.R. 10366, No Federal License-Plate Observation and Camera Keeping Act. Introduced September 14, 2026; referred to the House Committee on Transportation and Infrastructure; pending legislation. [Source](#)
- [17] Michigan Office of the Auditor General, Michigan Integrated Data Automated System (MiDAS), Performance Audit 641-0593-15, February 2016. <https://audgen.michigan.gov/complete-projects/michigan-integrated-data-automated-system-midas/>
- [18] Michigan Attorney General, State Announces Settlement of Civil Rights Class Action Alleging False Accusations of Unemployment Fraud, October 20, 2022. <https://www.michigan.gov/ag/news/press-releases/2022/10/20/som-settlement-of-civil-rights-class-action-alleging-false-accusations-of-unemployment-fraud>
- [19] Michigan Unemployment Insurance Agency, General MiUI Questions. Tax functionality launched February 23, 2026; benefits functionality is scheduled for November 9, 2026. <https://www.michigan.gov/leo/bureaus-agencies/uia/miui-university/miui-faq/miui-for-employers/miui>
- [20] Michigan DTMB, Adoption and Usage of Artificial Intelligence: Guidelines and Responsibilities, Public Version 1.9, August 2025. <https://www.michigan.gov/dtmb/-/media/Project/Websites/dtmb/Law-and-Policies/Governance/State-of-MichiganDTMBAdoption-and-Usage-of-Artificial-IntelligenceGuidelines-and-Responsibilities--P.pdf>
- [21] Michigan Department of Education, Artificial Intelligence Guidance. <https://www.michigan.gov/mde/services/academic-standards/educational-technology/artificial-intelligence>

Editorial note: This brief is independent policy analysis for research and educational purposes. It does not constitute legal advice, a vendor endorsement, or a recommendation on a specific contract. Descriptive findings are separated from NCI policy recommendations and implementation proposals.